

SECURECLOUD 2.0 ENTERPRISE SOC MANUAL

Threat Intelligence Correlation • SOAR Policies • User Risk Matrix • Incident Playbooks

1. EXECUTIVE OVERVIEW & ARCHITECTURE

SecureCloud is an enterprise cloud storage security platform featuring LightGBM machine learning threat inference, graph-based threat correlation, Security Orchestration, Automation, and Response (SOAR) policies, and dynamic user behavioral risk matrix profiling. This operational manual provides Security Operations Center (SOC) administrators and system users with step-by-step procedures to understand, execute, and respond to incidents.

2. THREAT INTELLIGENCE CORRELATION ENGINE (/admin/correlation)

What It Does: Rather than analyzing file uploads in isolation, the Correlation Engine uses graph analytics to connect disparate telemetry signals across the entire system into actionable **Threat Clusters**.

Telemetry Point	Correlation Mechanism	Threat Detection Objective
File SHA-256 Hashes	Tracks cross-account identical payload distribution	Detects coordinated malware spreading
Obfuscated Extensions	Flags double-extensions (e.g. .pdf.exe, .zip.iso)	Prevents Trojan disguise deception
IP Address Anomalies	Monitors rapid ingress from non-standard ASNs/Tor nodes	Detects brute-force credential stuffing & bots
Shared Link Exfiltration	Tracks anomalous view/download spikes on shared links	Halts rapid external data exfiltration

How Admin Executes Mitigation:

1. Navigate to **SOC -> Correlation** in the admin navbar.
2. Inspect active clusters (e.g., *THREAT CLUSTER #0042: Coordinated Ingress & Dual-Stage Disguised PE Infiltration*).
3. Under Recommended Automated Actions, click '**Execute Mitigation**'.
4. **What Happens Immediately in the Backend:**
 - Associated IP addresses (e.g., 198.51.100.42, 203.0.113.19) are automatically added to **IP Guard** blacklist.
 - High-risk payloads across affected accounts are quarantined in the Quarantine Vault.
 - Active public share tokens associated with the threat are instantly revoked.
 - The cluster status changes live to **MITIGATED & RESOLVED (0% Threat Score)**.

Immediate User & Admin Response:

- **Administrator:** Review the Mitigation Report modal and confirm blacklisted IPs in IP Guard.
- **Affected User:** The user receives notification that suspicious files were quarantined. User should reset credentials and check active sessions.

3. SOAR SECURITY RESPONSE POLICIES ENGINE (/admin/policies)

What It Does: The SOAR engine provides autonomous, sub-second security orchestration that monitors system events in real-time and triggers defensive playbooks automatically without requiring human intervention.

Policy Rule Name	Trigger Condition (IF)	Autonomous Mitigation (THEN)
Rapid Malware Ingress Containment	Malicious payload uploads >= 2 within 10 minutes	→ Quarantine files → Revoke active public share links → Escalate Sentinel VM to Phase 3 → Trigger military breach siren alert
Brute Force IP Containment & Ban	Failed login attempts >= 5 from same IP in 5 min	→ Permanently blacklist IP in IP Guard → Terminate active sessions → Log critical SOC security alert
Repeated Suspicious Anomaly Escalation	User uploads suspicious files >= 3	→ Enforce mandatory 2FA on account → Notify SOC analyst → Increase user risk level

How Admin Executes & Tests Policies:

- **Automated Trigger:** Policies execute automatically when live telemetry thresholds are met during user uploads or login spikes.
- **Manual Execution:** On the policy card, click '**Test / Execute**'. The engine executes the real quarantine and revocation routines, increments the execution counter live, and updates the timestamp.
- **Audit Trail:** Click '**History**' on any policy card to review chronological execution records and exact actions applied.

4. USER RISK PROFILING MATRIX (/admin/risk-profiling)

What It Does: Assigns every account a multi-factor risk score (0 to 100) and classifies them into **CRITICAL (>=85)**, **HIGH (50-84)**, **MEDIUM (25-49)**, and **LOW (<25)** tiers based on real behavior.

Risk Metric	Weight / Impact	Underlying Evidence Evaluated
Malicious Uploads	High (+30 to +50 pts)	Payloads identified as malware by LightGBM model
Suspicious Uploads	Medium (+15 to +25 pts)	High entropy, PE headers, or disguised extensions
Failed Auth Spikes	Medium (+10 to +20 pts)	Repeated bad password attempts in audit logs
Public Link Exposure	Low (+5 to +10 pts)	Volume of unrestricted active download links
2FA Compliance	Mitigating (-20 pts)	Active Two-Factor Authentication reduces overall account risk

Administrative Remediation Actions:

1. **Enforce 2FA:** Clicking *'Enforce 2FA'* immediately sets `two_factor_enforced=True` in the database. The user will be required to configure TOTP upon their next authentication, and their risk score drops by 20 points.
2. **Lockdown User:** Clicking *'Lockdown User'* terminates all active sessions in `user_sessions`, revokes public share tokens, and marks the user as LOCKED DOWN. The user cannot access repositories until restored.

5. CONFIDENTIAL VAULT PROGRESSIVE LOCKOUT & COUNTDOWN

Zero-Knowledge Architecture: Files in the Confidential Vault are encrypted using AES-256-GCM with PBKDF2 PIN key derivation. Administrators cannot access or view plain content.

Progressive Lockout Enforcement:

- **Stage 0 (Active):** User has 3 consecutive attempts. After attempt 2, system warns: *'Only 1 attempt remaining before 30-minute lockout!'*
- **Stage 1 (30-Minute Lockout):** After 3 consecutive failed PIN attempts, file enters a 30-minute lockout. A live countdown timer (mm:ss remaining) displays at the side of the file card and inside the unlock modal. PIN input is disabled.
- **Stage 2 (2-Hour Lockout):** If unlocked after 30 minutes and 3 additional incorrect PINs are entered, file locks for 2 hours (01h 59m 59s remaining).
- **Stage 3 (Permanent Vault Lock):** If 3 further failed attempts occur, the file is **permanently locked**. The key derivation slot is wiped to protect confidential data from brute force.
- **Auto-Expiry Recovery:** As soon as the countdown timer hits 00:00, the frontend automatically re-enables the PIN input and refreshes vault status.